

MobiCova Digital Health

Security & Integration Whitepaper

How we protect partner and member data, and how we connect to your infrastructure securely.

Audience: Chief Security Officer, Chief Technology Officer, and technical due-diligence teams of partner organisations.

Version 1.0 · Classification: Confidential · B2B digital-health infrastructure (MVP)

1. Executive summary

MobiCova is a B2B digital-health platform. Partner organisations — insurers, employers, telcos, and cooperatives — use MobiCova to enrol and manage members and to deliver three integrated services: telemedicine, an AI health assistant, and health-linked insurance. MobiCova is positioned as a Health Platform, Distributor, and Infrastructure Provider: it connects members to licensed clinical and insurance providers, it does not provide those services itself.

This document describes the security architecture of the platform, the controls already in production, our hardening roadmap, and the patterns by which we integrate with partner systems. It is written for security and engineering leaders evaluating MobiCova for a pilot.

Security model in one line: every request is authenticated and authorised, every tenant's data is isolated, all traffic is encrypted, all secrets are externalised, and all database access is parameterised against injection.

2. Architecture overview

The platform is a conventional, well-understood three-tier web architecture, which keeps the attack surface small and auditable:

- **Client:** a React single-page application served as static assets over HTTPS. It holds no secrets and talks only to the API.
- **API:** a stateless Node.js / Express service exposing a versioned REST API under /api/v1. It enforces authentication, authorisation, validation, and rate limiting.
- **Data:** a managed PostgreSQL database (Supabase / Neon), encrypted at rest, reached over TLS.
- **Channels & partners:** member intake over WhatsApp (Meta Cloud API) and USSD (telco aggregator); payments via Paystack / Stripe; AI triage via the Anthropic API. Each is an outbound, least-privilege integration.

The API is stateless: identity travels in a signed token on each request, so there is no server-side session store to compromise and the service can be scaled or replaced without affecting security state.

3. Data flow

A typical authenticated request follows the same path, with a security check at each hop:

- A partner admin authenticates; the API verifies the password (bcrypt) and issues a short-lived signed JSON Web Token (JWT) carrying the user, organisation, and role.
- The browser sends the token as a Bearer credential over HTTPS on every subsequent request.
- The API verifies the token signature, then authorises the action — tenant routes are scoped to the caller's organisation; platform-admin routes require an explicit privilege.
- Database access uses parameterised queries only; user input is never concatenated into SQL.
- Member intake from WhatsApp/USSD is attributed to the correct organisation by a per-organisation join code before any record is written.

4. Security controls in production

The following controls are implemented and live today:

Domain	Control	Status
Transport	TLS (HTTPS) for all client, API, and database traffic; HSTS via security headers	Live
HTTP hardening	Helmet security headers (no-sniff, frame-deny, HSTS, etc.)	Live
Cross-origin	CORS restricted to a single trusted client origin (not wildcard)	Live
Authentication	Signed JWT bearer tokens, verified server-side on every request	Live
Passwords	bcrypt hashing (12 rounds); policy enforces length + letter/number	Live
Injection	Fully parameterised SQL across the codebase — no string-built queries	Live
Brute force	Rate limiting: strict on auth endpoints, baseline across the API	Live
Authorisation	Per-tenant scoping plus a platform-admin guard on all admin routes	Live
Webhook integrity	Raw-body signature verification for payment-provider callbacks	Live
Secrets	All secrets in environment variables, never in source control	Live
Tenant lifecycle	Organisations can be suspended, which blocks all of their logins	Live

5. Authentication & authorisation

Authentication uses signed JWTs. Passwords are never stored or logged in plaintext; they are hashed with bcrypt at a work factor of 12. The password policy requires a minimum length and a mix of letters and numbers, enforced uniformly across self-service registration and administrator-provisioned accounts.

Authorisation is two-tier. Each token carries the user's organisation, so tenant data access is scoped to that organisation. A separate platform-admin privilege — granted by an explicit database flag or an environment allow-list — gates the administrative console (organisation, user, plan, and partner management). All administrative routes sit behind this guard server-side; hiding the UI is treated as convenience, not as a security control.

6. Data protection & privacy

- **Encryption in transit:** TLS 1.2+ for all connections, including to the database.
- **Encryption at rest:** provided by the managed PostgreSQL platform.
- **Data minimisation:** only the fields required to deliver a service are collected. In this MVP, clinical providers and insurers are represented as partner records and mock integrations, and no real protected health information (PHI) is entered.
- **Regulatory alignment:** the design anticipates the Nigeria Data Protection Act 2023 (NDPA) and the oversight of the Nigeria Data Protection Commission, including lawful-basis, data-subject-rights, and data-residency considerations for pan-African partners.

7. Multi-tenant isolation

Each partner organisation is a logically isolated tenant. Every tenant-scoped query is filtered by the organisation identifier carried in the authenticated token, so one partner cannot read or modify another partner's members, users, or records. As defence-in-depth, database-level Row-Level Security is on the roadmap so isolation is enforced by the database engine in addition to the application layer.

8. Secure integration with partner infrastructure

When we connect to a partner's systems, we apply direction-specific controls and document each integration.

8.1 Inbound (partner systems calling MobiCova)

- Per-tenant API credentials (API keys or OAuth 2.0 client-credentials), scoped to a single organisation, individually revocable and rotatable.
- HMAC-signed webhooks so the partner can cryptographically verify that a callback genuinely originated from MobiCova — the same signature pattern already used for payment callbacks.
- Optional IP allow-listing per tenant and per-credential rate limiting; mutual TLS available for partners who require it.

8.2 Outbound (MobiCova calling partner systems)

- Partner credentials held in a secrets manager, encrypted at rest, never in source control.
- Least-privilege scopes, full TLS certificate verification, and resilience patterns (timeouts, retries, circuit breaking) so a partner outage cannot cascade.

8.3 Documentation provided

- A data-flow description, an integration specification (endpoints, auth, payloads), and this security whitepaper, supplied to the partner's security team for review before go-live.

9. Operational security

- **Secrets management:** all secrets are injected as environment variables at deploy time; the token-signing secret is generated by the platform and not known to any individual. Source control contains only non-secret example templates.
- **Deployment:** reproducible, Git-driven deploys; TLS terminated at the platform edge.
- **Separation:** client and API are deployed as separate services with distinct trust boundaries.
- **Incident posture:** the database connection fails closed on unexpected errors; the planned audit log (below) will provide an authoritative trail of administrative actions.

10. Security hardening roadmap

We are explicit about what is in place versus planned. The following enhancements are prioritised for the pilot phase:

- **Token revocation on suspension:** immediate invalidation of already-issued tokens when a tenant or user is suspended, via short-lived access tokens with refresh, or a token-version check.
- **Multi-factor authentication:** TOTP-based MFA for administrator accounts.
- **Single sign-on:** SAML / OIDC so partners can use their corporate identity provider (e.g. Microsoft Entra, Okta).
- **Audit logging:** an append-only record of administrative actions, visible to platform and tenant administrators.
- **Database Row-Level Security:** engine-enforced tenant isolation in addition to the application layer.
- **Certificate pinning:** verification of the database TLS certificate against a pinned CA (already supported via configuration).
- **Credential hygiene:** breached-password screening and a formal secret-rotation policy.

11. Summary

MobiCova ships with a strong, conventional security baseline — encrypted transport, signed-token authentication, two-tier authorisation, injection-safe data access, rate limiting, and externalised secrets — and a clear, prioritised roadmap toward enterprise controls such as MFA, SSO, audit logging, and database-enforced tenant isolation. Our integration approach is credential-scoped, signed, least-privilege, and documented for partner review. We welcome a technical deep-dive with your security and engineering teams.

This document describes an MVP under active development. Controls marked “Live” are implemented; roadmap items are planned and may change. Shared in confidence for evaluation purposes.